NoScope - Finding RCE

Alf.io is an open-source, Java/Spring Boot event management platform used by conference organizers, sports clubs, and ticketing services worldwide. It ships with an extension system that lets administrators run custom JavaScript scripts in response to platform events, like ticket assignments and invoice generation.

To isolate those scripts from the underlying JVM, Alf.io uses a JavaScript sandbox backed by Mozilla Rhino. Scripts are validated against a blocklist before execution, where patterns like `java.lang.Runtime` and reflection keywords are rejected. The assumption: a script that can't name a dangerous class can't reach one.

CVE-2026-35482 breaks that assumption. It was discovered autonomously by NoScope. NoScope conducted a full automated pentest against the target, identified the unusual `returnClass` binding, confirmed it was exploitable end-to-end, and generated a validated finding, all without ever looking at the code. No static analysis or pentesting tool had caught it before.

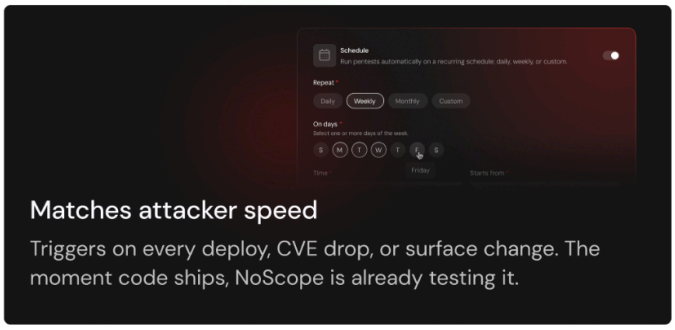
Alf.io injects a variable called `returnClass` into every script's scope, a raw Java `Class<T>` object intended as a convenience for scripts that need to declare their return type. Because `Class<T>` exposes `Class.forName()`, an attacker can load any JVM class by passing its name as a string argument, which the blocklist never inspects. From there, Java reflection gives full access to `Runtime.exec()` and arbitrary OS command execution.

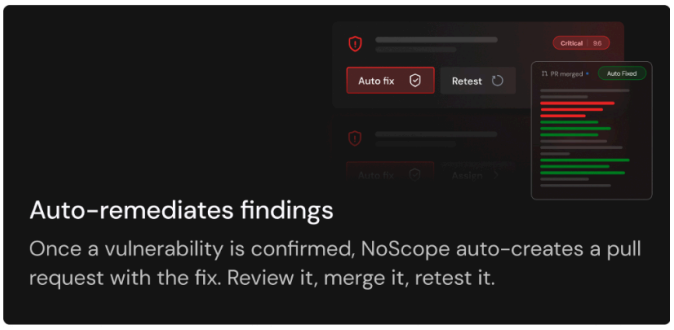
NoScope responsibly disclosed the vulnerability to the Alf.io maintainers and coordinated the CVE assignment before publishing.

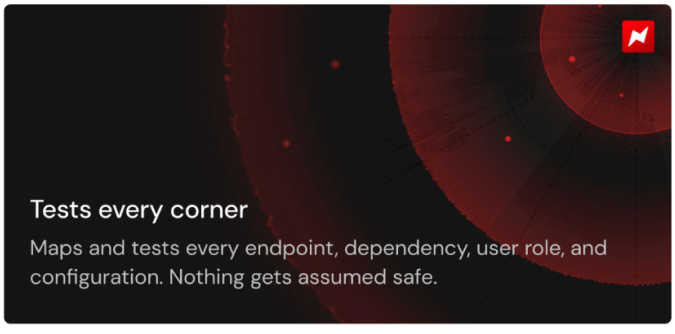
Vulnerability Hunting with NoScope

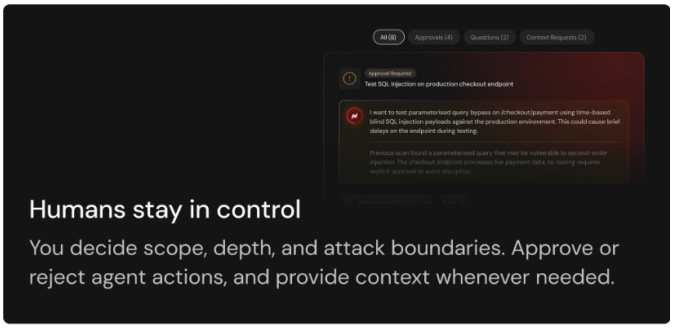
What Is NoScope?

is an AI-based automated pentesting platform. It deploys specialized agents that map an application's attack surface, build an attack graph, generate targeted payloads, and confirm exploitability end-to-end before surfacing anything as a finding. Nothing gets flagged unless it's been proven.

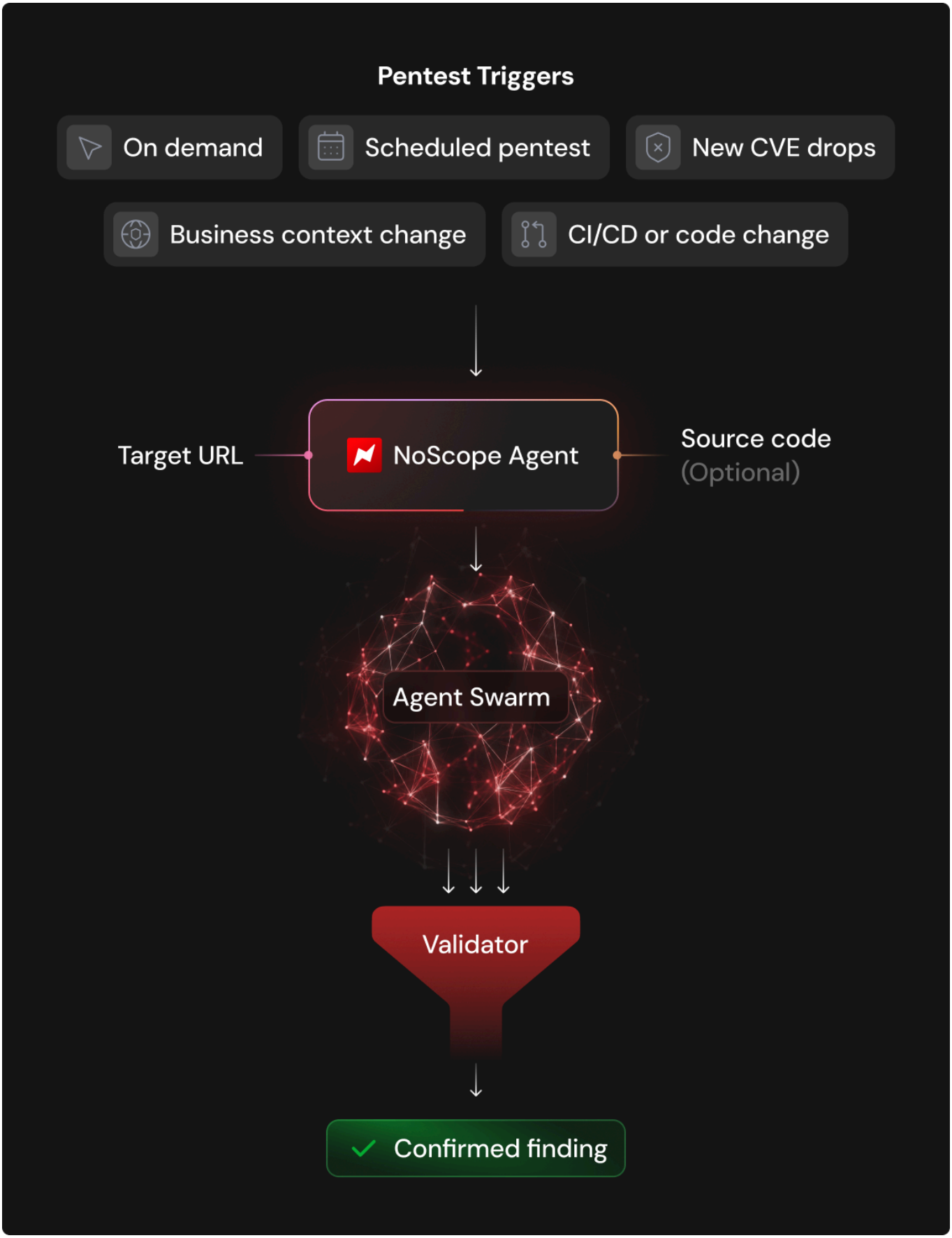






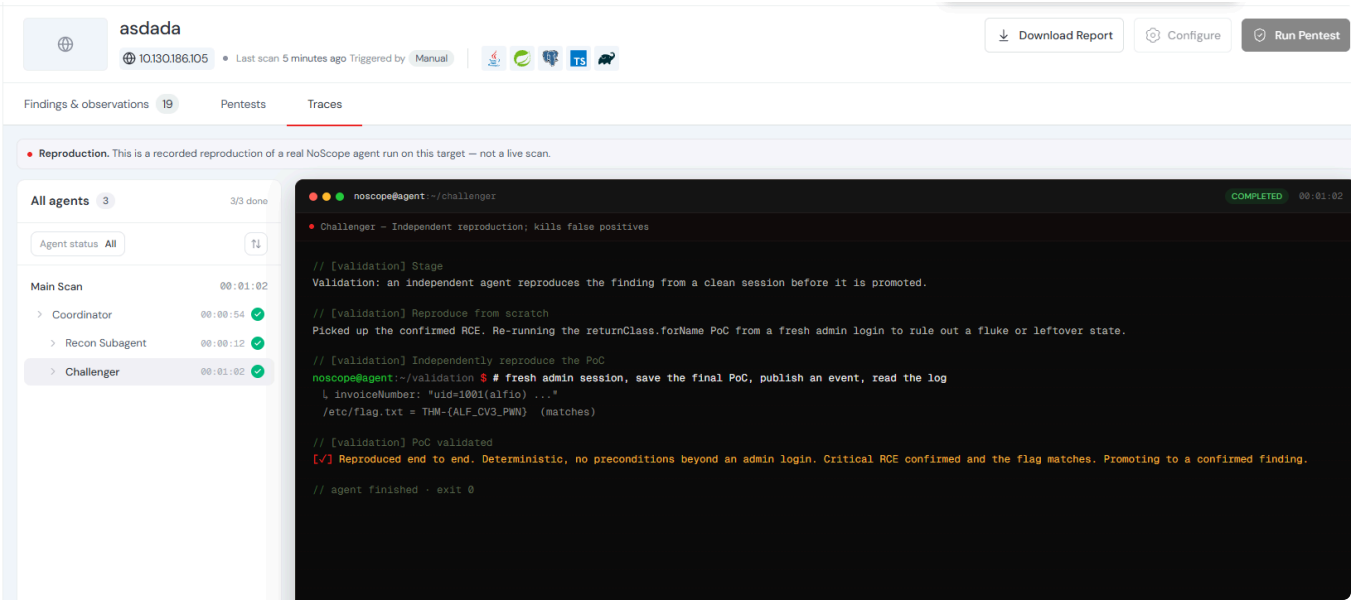


How Does NoScope Work?

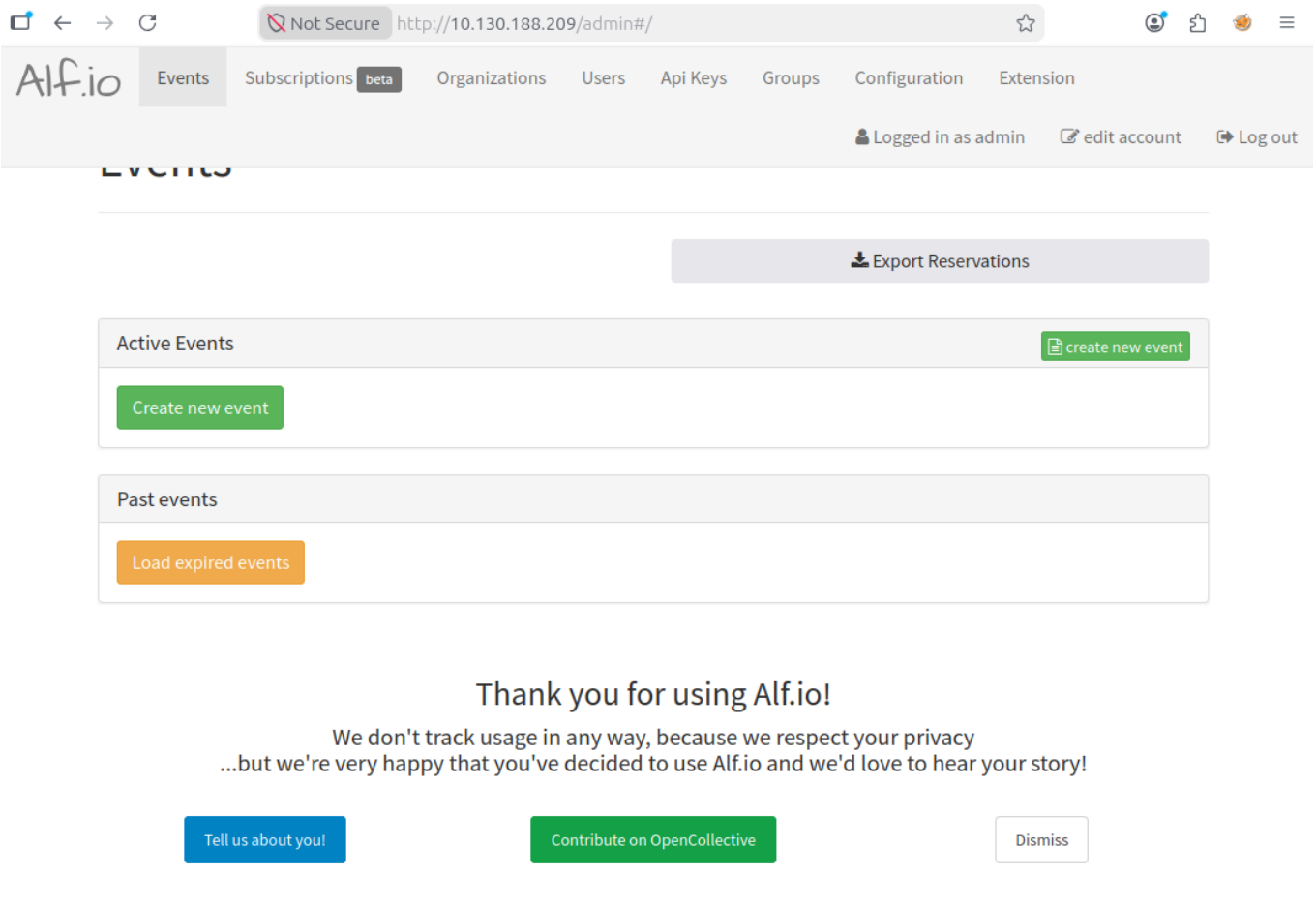


I opened NoScope and ran a pentest on the IP of the target

it then did a bunch of commands fingerprinting and exploiting the application and It eventually produced the flag



Weaponising the CVE



I logged into the admin account

You have identified that the target is running Alf.io 2.0-M5-2509-1, a version vulnerable to CVE-2026-35482. You have also obtained valid administrator credentials for the admin panel and noticed an event has already been set up.

I set up a python server and a listener and a reverse shell script.

under extension i made a new extension and pasted in a reverse shell i then saved that and published the event and it executed and I got the reverse shell on the listener.